Semana 10 — Auditoria de alcance cerrado, informe y defensa

Trabajo individual · ejemplo de cierre

Prof. César Rodríguez | ELECTRONICA | 1 de noviembre de 2026

Curso	CYBERSEGURIDAD — Ciberseguridad Aplicada
Semana	10 de 10
Fase	5 — Cierre
Trabajo	Individual (cierre del curso)
Entrega	GitHub, carpeta semana_10/
Corte	Domingo 23:59 de la semana correspondiente; lo posterior no se corrige.

1 Trabajo individual

El cierre no reparte responsabilidad por roles: cada sección del entregable se defiende completa y con evidencia propia.

2 Ejemplo paso a paso

Ejemplo de cierre para el trabajo individual. El recorrido completo en cuatro horas: aceptar el alcance, reconocer, explotar de forma controlada, preservar la evidencia y comunicar en dos registros. No hay roles: cada estudiante responde por todo el ciclo.

2.1 Aceptar el alcance antes de ejecutar

Se firma la aceptacion con activos incluidos, ventana y limites. El reloj de las cuatro horas empieza cuando la aceptacion esta firmada, no antes.

```
mkdir -p semana_10/evidencia
date -u +%FT%TZ > semana_10/evidencia/inicio.txt
sha256sum semana_10/alcance_firmado.pdf > semana_10/evidencia/alcance.
    sha256
```

2.2 Reconocimiento y explotacion controlada

Se documenta la superficie observada y se elige un hallazgo para explotar. La explotacion se detiene en la prueba: no se extraen datos ni se persiste acceso.

```
nmap -sT -p 8081,3000,2222 --max-rate 20 127.0.0.1 \
  -oN semana_10/evidencia/nmap.txt
curl -s -b semana_10/evidencia/cookies.txt \
  'http://127.0.0.1:8081/vulnerabilities/xss_r/?name=%3Cscript%3Ealert
     (1)%3C/script%3E' \
  > semana_10/evidencia/xss_antes.html
```

2.3 Preservar la evidencia con hash

Cada pieza se hashea al producirse y el conjunto se sella al final. La evidencia anonimizada es la que se versiona; la cruda queda fuera del repositorio.

```
sha256sum semana_10/evidencia/*.txt semana_10/evidencia/*.html \
  > semana_10/evidencia/evidencia.sha256
sed -E 's/[A-Za-z0-9._%+-]+@[A-Za-z0-9.-]+/[correo]/g' \
  semana_10/evidencia/xss_antes.html \
  > semana_10/evidencia/xss_anonima.html
```

2.4 Aplicar y verificar la mitigacion

Se aplica el control y se repite el mismo payload. La defensa se demuestra con el antes y el despues, igual que en la semana 7.

2.5 Redactar los dos registros

El informe tecnico cita evidencia y causa raiz; el resumen ejecutivo explica el riesgo y la decision sin jerga. La defensa oral reconoce los limites del alcance.

2.6 Producto, contenido y criterio

Producto, contenido y criterio

Producto	Contenido	Evidencia	Criterio
Alcance aceptado	Activos, ventana y limites	alcance.sha256	Cobertura declarada
Reconocimiento	Puertos y servicios observados	nmap.txt	Evidencia verificable
Explotacion	Payload y resultado	xss_antes.html	Hallazgo trazable
Mitigacion	Control y repeticion	xss_despues.html	Control demostrado
Informe tecnico	Hallazgos, causa y remediacion	evidencia.sha256	Precision y trazabilidad
Resumen ejecutivo	Riesgo y decision en lenguaje llano	resumen.md	Comprensible sin jerga
Defensa oral	Decisiones y limitaciones	guion.md	Reconoce limites

La columna de evidencia se llena con el archivo concreto; un criterio sin archivo que lo respalde no esta cubierto.

3 Qué guardar en el repositorio

Se entrega el informe tecnico, el resumen ejecutivo, la evidencia anonimizada con su hash y el guion de la defensa oral, con el alcance firmado al inicio.

```
semana_10/
|-- alcance_firmado.pdf
|-- informe_tecnico.md
|-- resumen_ejecutivo.md
|-- guion.md
|-- evidencia/
|   |-- inicio.txt
|   |-- nmap.txt
|   |-- xss_antes.html
|   |-- xss_anonima.html
|   |-- xss_despues.html
|   `-- evidencia.sha256
`-- README.md
```

- El alcance esta firmado antes de la primera prueba.
- Cada hallazgo del informe tecnico cita un archivo de evidencia.
- El resumen ejecutivo se entiende sin conocer las herramientas.
- La defensa oral declara al menos una limitacion del alcance.
- La evidencia versionada esta anonimizada y sellada con hash.

4 Cómo se corrige

Criterio	Peso
Cobertura completa del alcance declarado	3,0
Evidencia preservada y verificable	2,5
Informe técnico preciso y trazable	2,0
Resumen ejecutivo comprensible sin jerga	1,5
Defensa oral que reconoce limitaciones	1,0
Total	**10,0**

- {'Las cuatro horas incluyen la redaccion': 'se reserva al menos una hora para escribir.'}
- No se explota nada fuera del alcance aunque quede tiempo disponible.

Recuerda

El trabajo es independiente: cada grupo usa su propio repositorio y su propio laboratorio, y la comparación de resultados es en clase. Corte: Domingo 23:59 de la semana correspondiente; lo posterior no se corrige.